

API Interview Questions and Answers

1. What is an API?

Answer:

- API stands for Application Programming Interface.
- It is a set of rules and protocols for building and interacting with software applications.
- APIs allow different software systems to communicate with each other.
- They are used to access web-based services.
- Example: A weather app using a weather API to get forecast data.

2. What are the types of APIs?

Answer:

- Open APIs (Public): Available to developers and users with minimal restrictions.
- Partner APIs: Shared with business partners, access requires specific rights.
- Internal APIs (Private): Used within an organization.
- Composite APIs: Combine multiple data or service APIs.

3. What is REST API?

Answer:

- REST stands for Representational State Transfer.
- It is an architectural style for designing networked applications.
- REST uses HTTP methods: GET, POST, PUT, DELETE.
- It works on resources identified by URIs.
- It is stateless, meaning each request is independent.

4. What are HTTP methods supported by REST?

Answer:

- GET – Retrieve data.
- POST – Create a new resource.
- PUT – Update an existing resource.
- DELETE – Remove a resource.
- PATCH – Partial update of a resource.

5. What is the difference between PUT and POST?

Answer:

- PUT is idempotent, meaning multiple identical requests result in the same effect.
- POST is not idempotent; used to create resources.
- PUT updates/replaces the resource; POST adds a new one.
- PUT requires a full payload; POST can be partial.

6. What is an endpoint in API?

Answer:

- An endpoint is a specific URL where an API can access the resources.
- It acts as the point of contact between the API and the client.
- Example: `/api/users/123` is an endpoint to access user data.

7. What is JSON and XML in APIs?

Answer:

- JSON (JavaScript Object Notation) is lightweight, easy to read and commonly used.
- XML (eXtensible Markup Language) is verbose, used in older APIs.
- Both are used to transfer data between client and server.

8. What is status code 200, 201, 400, 401, 404, 500 in API?

Answer:

- 200 – OK (Success)
- 201 – Created (New resource created)
- 400 – Bad Request (Invalid input)
- 401 – Unauthorized (Authentication required)
- 404 – Not Found (Resource not available)
- 500 – Internal Server Error

9. What is API testing?

Answer:

- **API Testing** is a type of software testing that focuses on APIs.
- It checks functionality, reliability, performance, and security.
- Done using tools like Postman, SoapUI, or automated tests.

10. What is Postman?

Answer:

- Postman is a popular API client tool.
- It allows users to test, document, and monitor APIs.
- Supports HTTP methods like GET, POST, PUT, DELETE.
- Offers features like environment variables and test scripts.

11. What is Authentication and Authorization in API?

Answer:

- Authentication: Verifies user identity (e.g., login with credentials).
- Authorization: Checks if user has access to resources.
- Example: Authenticated user may be authorized to view orders.

12. What are Headers in API?

Answer:

- Headers provide metadata for requests and responses.
- Common headers: Content-Type, Authorization, Accept.
- Help in processing requests correctly.

13. What is a Payload in API?

Answer:

- Payload is the body of the request or response.
- It contains the actual data (e.g., JSON object) to be processed.

14. What is OAuth 2.0?

Answer:

- OAuth 2.0 is an authorization framework.

- It allows third-party applications to access user resources without sharing credentials.
- Uses tokens to grant access securely.

15. What is rate limiting in APIs?

Answer:

- It restricts the number of API calls in a given time.
- Prevents abuse and overload of servers.
- Example: 1000 API calls/hour per user.

16. What is CORS in APIs?

- CORS stands for Cross-Origin Resource Sharing.
- A security feature in web browsers.
- It allows or blocks resources from different origins.

17. What is Swagger?

- Swagger is a framework for documenting RESTful APIs.
- Now known as OpenAPI Specification.
- Allows auto-generation of documentation and client SDKs.

18. What is RESTful vs SOAP API?

- REST is lightweight, uses HTTP, supports JSON/XML.
- SOAP is protocol-based, XML only, has strict rules.
- REST is more popular for web APIs.

19. What is an API key?

- API key is a unique identifier used to authenticate a client.

- Passed in headers or query params.
 - Used for monitoring and securing APIs.
-

20. What is a mock API?

Answer:

- A simulated API that mimics the behavior of a real API.
 - Used during development/testing before the real backend is ready.
-

21. What is versioning in API?

Answer:

- It's the process of updating APIs without breaking existing functionality.
 - Version can be included in the URL or headers.
 - Example: /api/v1/users
-

22. What is latency in API?

Answer:

- A server that acts as an API front-door.
 - Handles authentication, rate limiting, routing, etc.
 - Example: AWS API Gateway, Kong, Apigee
-

23. What is API Gateway?

Answer:

- A server that acts as an API front-door.
 - Handles authentication, rate limiting, routing, etc.
 - Example: AWS API Gateway, Kong, Apigee
-

24. What are some common tools for API testing?

Answer:

- Postman
- SoapUI
- JMeter
- Rest Assured

- Swagger Inspector

25. What are idempotent methods in REST API?

Answer:

- Methods that give the same result no matter how many times they are called
- Example: GET, PUT, DELETE are idempotent.
- POST is not idempotent.

26. What is the difference between synchronous and asynchronous APIs?

Answer:

- Synchronous APIs: Client waits for the server to process and respond.
- Asynchronous APIs: Request is processed in the background, and response is returned later (via polling, callbacks, or webhooks).
- Sync = blocking, Async = non-blocking.

27. What is a REST resource?

Answer:

- A resource is an object or data represented by a URI.
- Example: /users/123 is a user resource with ID 123.
- Resources can be manipulated using HTTP methods.

28. What is HATEOAS in REST?

Answer:

- HATEOAS: Hypermedia As The Engine Of Application State
- It means REST responses include hyperlinks to related resources.
- Enhances discoverability of the API.

29. What are query parameters and path parameters?

Answer:

- Path Parameters: Part of the URL (e.g., /users/{id}).
- Query Parameters: Passed after ? in URL (e.g., /users?id=1).
- Path → identifies resource; Query → filters or modifies.

30. What is the difference between 401 and 403 HTTP status codes?

Answer:

- 401 Unauthorized: User is not authenticated.
- 403 Forbidden: User is authenticated but not allowed to access.

31. What is a token in APIs?

Answer:

- A token is a string used for security/authentication.
- Common types: JWT (JSON Web Token), OAuth token.
- Used to access protected resources.

32. What is RESTful routing?

Answer:

- It follows a consistent pattern for URLs and actions.
- Example:
 - GET /users - List users
 - POST /users - Create user
 - GET /users/1 - Get user
 - PUT /users/1 - Update user
 - DELETE /users/1 - Delete user

33. What is the use of the OPTIONS method in HTTP?

Answer:

- OPTIONS returns allowed HTTP methods for a URL.
- Commonly used in CORS preflight checks.
- Example: GET, POST, OPTIONS in response.

34. What are environment variables in Postman?

Answer:

- Variables to store values like base URL, API keys.
- Help switch between dev, test, and prod environments.

- Example: `{{base_url}}/users`

35. What is API documentation?

Answer:

- It describes how to use the API, with examples and responses.
- Helps developers understand and integrate the API.
- Tools: Swagger, Redoc, Postman Docs.

36. What is throttling in APIs?

Answer:

- Controlling the number of API requests a user can make.
- Protects backend from being overwhelmed.
- Implemented using rate limits or quotas.

37. What is a webhook?

Answer:

- A webhook is an event-driven callback.
- The server sends data to a client URL when an event occurs.
- Example: Payment success triggers a webhook.

38. What are the best practices for designing REST APIs?

Answer:

- Use meaningful resource names.
- Follow HTTP methods appropriately.
- Use status codes correctly.
- Version your API.
- Provide proper error messages.

39. How do you secure an API?

Answer:

- Use HTTPS.

- Token-based authentication (OAuth, JWT).
- Rate limiting.
- Input validation and sanitization.
- IP whitelisting and API gateways.

40. What is pagination in REST APIs?

Answer:

- Breaking large results into smaller chunks.
- Achieved using parameters like limit, offset, page.
- Example: /users?page=2&limit=10

41. What is the purpose of the Content-Type header?

Answer:

- Tells the server or client the format of the request/response body.
- Example: application/json, application/xml, text/plain.

42. How do you handle errors in REST APIs?

Answer:

- Return proper HTTP status codes (e.g, 400, 404, 500).
- Include helpful error messages in response body.
- Structure errors in JSON (e.g., { "error": "Invalid ID" }).

43. What is the difference between SOAP and REST APIs?

Feature	SOAP	REST
Protocol	XML-based	HTTP-based
Format	Only XML	JSON/XML

Flexibility	Rigid	Flexible
Speed	Slower	Faster
Use Case	Enterprise apps	Web/Mobile apps

44. What is a schema in API?

Answer:

- A schema defines the structure of data (e.g., JSON Schema).
- Ensures input/output formats are validated.
- Helpful in API testing and documentation.

45. What is idempotency in REST?

Answer:

- Making multiple identical requests results in the same outcome.
- Methods like PUT, DELETE, and GET are idempotent.
- POST is not.

46. What is the difference between REST and GraphQL?

Answer:

- REST: Multiple endpoints, fixed structure.
- GraphQL: Single endpoint, flexible queries.
- GraphQL is more efficient for complex or nested data.

47. What is Postman collection?

Answer:

- A set of saved API requests grouped together.
- Helps organize test cases and workflows.
- Can be exported and shared.

48. What is an integration test in API?

Answer:

- Tests the interaction between modules/services via API.
- Validates correct data flow and communication.
- Example: Test user login + order placement.

49. What are common response formats in APIs?

Answer:

- JSON: Most widely used.
- XML: Older format, still in use.
- Text/HTML: Rarely used, mostly for debugging.

50. What are custom headers in API requests?

Answer:

- Headers defined by developers for specific needs.
- Example: X-Auth-Token, X-Client-ID.
- Used for tracking, authentication, debugging.

51. What is a contract in API development?

Answer:

- A contract defines the expected input and output of an API.
- It includes request structure, parameters, headers, and response format.
- Tools like Swagger/OpenAPI define contracts clearly.
- Contract-first development ensures client-server alignment.

52. What is an API Gateway and its role?

Answer:

- API Gateway is a server that acts as a reverse proxy.
- Manages traffic, routing, authentication, rate limiting, logging.
- Examples: Kong, AWS API Gateway, Apigee, Nginx.

53. What is JSON Schema and why is it useful in APIs?

Answer:

- JSON Schema defines the **structure** and **validation** rules of JSON data.
- Helps in request/response validation.
- Ensures consistency and catches errors early.

54. What is the difference between Monolithic and Microservices APIs?

Answer:

- **Monolithic:** One large codebase exposing APIs.
- **Microservices:** Independent services with their own APIs.
- Microservices are scalable, loosely coupled, and fault-tolerant.

55. What is a JWT (JSON Web Token)?

Answer:

- JWT is a secure, compact token used for authentication.
- Contains three parts: Header, Payload, Signature.
- Stateless, no need to store session data on the server.

56. How do you handle versioning in REST APIs?

Answer:

- **URI versioning:** /api/v1/users
- **Header versioning:** Accept: application/vnd.api.v1+json
- **Query parameter:** /users?version=1
- Ensures backward compatibility for clients.

57. What are some common API response status codes?

Answer:

- 200 OK: Successful GET
- 201 Created: POST success
- 204 No Content: DELETE success
- 400 Bad Request: Invalid input
- 401 Unauthorized: Auth required
- 403 Forbidden: Permission denied
- 404 Not Found: Resource missing
- 500 Internal Server Error: Server issue

58. How do you monitor APIs in production?

Answer:

- Use logging for requests, errors, and performance.
- Integrate with tools like New Relic, Datadog, Prometheus, or ELK stack.
- Setup alerts for high error rates or latency.

59. What is the difference between API mocking and stubbing?

Answer:

- **Mocking:** Simulates real API behavior for development/testing.
- **Stubbing:** Hardcoded responses for fixed conditions.
- Mocking is more dynamic; stubbing is simpler.

60. What is the difference between GET and HEAD methods?

Answer:

- **GET:** Retrieves resource with response body.
- **HEAD:** Retrieves headers only, no response body.
- Useful for checking metadata or availability.

61. What is GraphQL and how is it different from REST?

Answer:

- GraphQL is a query language for APIs.
- Clients specify exactly what data they need.
- Uses a single endpoint, unlike REST's multiple.
- Efficient for fetching nested or complex data.

62. How do you test APIs in automation frameworks?

Answer:

- Use tools like Rest Assured (Java), HTTPClient, or SuperTest (JavaScript).
- Integrate with test runners like JUnit, TestNG, or Mocha.
- Validate status codes, response bodies, headers.

63. What is dependency injection in API services?

Answer:

- Injecting service dependencies (e.g., DB, logging) into APIs instead of hardcoding.
- Promotes modularity, testability, and scalability.

64. What is an OpenAPI Specification (OAS)?

Answer:

- A standard for describing REST APIs.
- Formerly called Swagger.
- Allows auto-generation of docs, SDKs, and mock servers.

65. What is an API proxy?

Answer:

- An intermediate layer between client and real API.
- Handles security, logging, caching, and transformation.
- Used in API gateways and platforms like Apigee.

66. How does caching work in APIs?

Answer:

- Client-side APIs: Run in browsers (e.g., DOM API, Fetch API).
- Server-side APIs: Run on backend systems (e.g., REST, SOAP, GraphQL).

68. What is the difference between client-side and server-side APIs?

Answer:

- Client-side APIs: Run in browsers (e.g., DOM API, Fetch API).
- Server-side APIs: Run on backend systems (e.g., REST, SOAP, GraphQL).

Answer:

- Accept: Tells server what content type client expects.
- Content-Type: Tells server what format the request body is in.
- Example: application/json, application/xml

69. What are some security vulnerabilities in APIs?

Answer:

- Injection attacks
- Broken authentication
- Excessive data exposure
- Rate limiting bypass
- Improper access controls

70. What is API orchestration?

Answer:

- Combining multiple services/APIs to fulfill a business process.
- Example: Booking API that calls payment, inventory, and email APIs.
- Can be implemented with tools like **Camunda**, **Apache Camel**.

71. What is the use of ETag in APIs?

Answer:

- ETag is an identifier for a resource version.
- Used for caching and conditional requests.
- Prevents sending full response if not changed.

72. What are the challenges of API development?

Answer:

- Security and authentication
- Rate limiting and throttling
- Consistent documentation
- Backward compatibility
- Monitoring and debugging

73. What is a SOAP envelope?

- A SOAP message structure with:
 - Envelope: Root element
 - Header: Optional metadata
 - Body: Contains the actual request/response
- XML-based and strictly formatted.

74. What is the difference between REST and RPC APIs?

- REST: Resource-based, uses HTTP verbs and URIs.
- RPC (Remote Procedure Call): Function-based, e.g., `getUser(id)`.
- REST is more scalable and decoupled.

75. How do you secure internal APIs?

- Use IP whitelisting or VPNs.
- Restrict access with internal auth tokens.
- Apply strict access control and audit logs.
- Avoid exposing them to public internet.

76. What are asynchronous callbacks in APIs?

- When an API request is processed asynchronously, a callback URL is provided.
- Once processing is complete, the server notifies the client by calling the callback URL.
- Used in webhooks, payment confirmations, etc.

77. What is the difference between synchronous vs asynchronous messaging in APIs?

- **Synchronous:** Immediate response expected, blocks the client.
- **Asynchronous:** Server responds later, allows the client to continue.
- Async improves scalability and user experience.

78. What is a 429 HTTP status code?

Answer:

- 429 Too Many Requests
- Sent when a user exceeds the API's rate limit.
- Used with rate limiting and throttling mechanisms.

79. What is the difference between soft delete and hard delete in APIs?

Answer:

- **Hard delete:** Removes the data permanently from the database.
- **Soft delete:** Marks data as deleted (e.g., `is_deleted = true`) but retains it for recovery or logging.
- Example: Istio, Linkerd.

80. What is a service mesh, and how does it relate to APIs?

Answer:

- A **service mesh** manages service-to-service communication (e.g., APIs).
- Provides features like **load balancing**, **observability**, **retry**, **circuit breakers**.
- Example: Istio, Linkerd.

81. What is a circuit breaker pattern in API communication?

Answer:

- Prevents **cascading failures** when an API is down.
- If a service fails repeatedly, further calls are temporarily blocked.
- Ensures system stability.

82. What is the purpose of API rate limiting?

- Controls traffic, avoids abuse, and protects backend services.
- Helps enforce fair usage policies.
- Example: 1000 requests/hour/user.

83. What is API-first design?

Answer:

- APIs are designed before the actual implementation begins.
 - Ensures clear communication, mock testing, and parallel development.
 - Promotes contract-first architecture.
-

84. How do you handle API response time issues?

Answer:

- Use caching (Redis, CDN).
 - Optimize database queries.
 - Asynchronous processing (queues).
 - Load balancing and horizontal scaling.
-

85. What is the difference between API Testing and Unit Testing?

Answer:

- **API Testing:** Validates endpoints, response, performance.
 - **Unit Testing:** Validates individual code functions/methods.
 - API tests are integration-level; unit tests are code-level.
-

86. What is an SDK in context of APIs?

Answer:

- Software Development Kit to simplify API usage.
 - Provides ready-made functions for authentication, requests, error handling.
 - Reduces manual work in calling raw APIs.
-

87. What is a base URL in REST API?

- The root URL for all API endpoints.
- Example: `https://api.example.com/v1`
- All endpoints are appended to this base URL.

88. What is API sprawl and how can it be managed?

Answer:

- Refers to the uncontrolled growth of APIs in an organization.
- Leads to duplicate or inconsistent APIs.
- Manage with API gateways, governance policies, documentation.

89. What is API gateway between PUT, PATCH, and POST?

Answer:

Method	Purpose	Idempotent
PUT	Full update	✓ Yes
PATCH	Partial update	✓ Yes
POST	Create resource	✗ No

90. What is API gateway throttling?

Answer:

- Limits how many requests can pass through the API Gateway.
- Prevents overuse of backend services.
- Controlled by quotas or usage plans.

91. What is the use of the Location header in an API response?

Answer:

- Used with 201 Created status.
- Indicates the URL of the newly created resource.
- Example: Location: /users/123

92. What is a hypermedia API?

Answer:

- API that uses HATEOAS principles.
- Provides hyperlinks in responses to guide next actions.
- Helps in building discoverable and flexible APIs.

93. What is the OPTIONS preflight request in CORS?

Answer:

- Sent before actual request to check server permissions.
- Ensures the client can make the cross-origin call.
- Server must respond with allowed methods and headers.

94. What is an API Registry?

Answer:

- A central directory of APIs in an organization.
- Tracks versions, endpoints, and metadata.
- Helps manage API lifecycle.
- Gateway = API layer, Load Balancer = infrastructure layer.

95. What is API Gateway vs Load Balancer?

Answer:

- API Gateway: Manages authentication, routing, throttling, transformations.
- Load Balancer: Distributes traffic across servers for scalability and availability.
- Gateway = API layer, Load Balancer = infrastructure layer.

96. How do you log API activity securely?

Answer:

- Mask sensitive data (passwords, tokens).
- Use unique request IDs for traceability.
- Store logs securely (e.g., with access controls, encryption).